

منصة شاهين الرقمية
سياسة تطوير الأنظمة وإدارة التغييرات
نوفمبر 2025



Internal

DO NOT COPY

الاسم المسجل : شركة الوثيقة الماسية لوساطة التأمين
المركز الرئيسي : طريق الشمامة , الربيع , الرياض
مسؤول المستند : مدير إدارة الجودة والتطوير

المحتويات	
1	المقدمة
2	الهدف من السياسة
3	تعريف
4	نطاق تطبيق السياسة
5	القطاعات والإدارات ذات العلاقة
6	الكيانات ذات العلاقة
7	قواعد عامة
8	مسؤولية السياسة
9	التعالم والتعليمات ذات العلاقة
10	حفظ السياسة
11	مخالفة السياسة



إدارة الجودة والتطوير Quality & Development Management

المادة (1): يحتوي هذا المستند على المعلومات المتعلقة بمنصة شاهين الرقمية ولا يجوز استخدام أو نسخ هذا المستند أو المعلومات التي يحتوي عليها كاملة أو جزءاً منها أو كشفه إلى الغير ما لم تقدم شركة الوثيقة الماسية (دايموند) موافقتها الكتابية على ذلك. لا يجوز تعديل أو حذف هذا التصريح المقيد في أي حالة من هذا المستند.

المادة (2): في حال وجود اختلاف بين النص العربي والإنجليزي فإن السيادة تكون للنص العربي.



معلومات السياسة				
سياسة تطوير الأنظمة وإدارة التغييرات			عنوان السياسة	
مُستحدثة			حالة السياسة	
لا يوجد			عنوان السياسة السابقة	
لا يوجد			تاريخ السياسة السابقة	
بعد مُرور سنتين من تاريخ اعتماد السياسة أو عند الضرورة			تاريخ المراجعة القادمة	
1SP0004			رقم المستند	
منصة شاهين الرقمية			مالك السياسة	
إدارة الجودة والتطوير			إعدت بواسطة	
مسؤولو القطاعات والإدارات الذين راجعوا السياسة ووافقوا عليها				
التوقيع	التاريخ	الاسم	الوظيفة	الإدارة
	2025-12-28	تركي عبدالله العبدلي	مدير إدارة الإلتزام والامتثال	الإدارة الرقابية
	2025-11-26	عنه: هاني هاشم	مدير إدارة الجودة والتطوير	رئيس مراجعة السياسات
اعتماد السياسة				
	2025-12-28	بدر سعد الشايع	العضو المنتدب	الإدارة العليا



إدارة الجودة والتطوير
Quality & Development Management

1. المقدمة:

1.1 تُعد سياسة سياسة تطوير الأنظمة وإدارة التغييرات جزءًا أساسيًا في تحديد إطار موحد لحوكمة تطوير الأنظمة، وضمان الالتزام بمعايير الأمن السيبراني، ومنع أي تغييرات غير مصرح بها قد تؤثر على الأداء التشغيلي أو سلامة البيانات.

2. الهدف من السياسة:

2.1 تثق شركة الوثيقة الماسية لوساطة التأمين (ويشار إليها فيما يلي بـ "شاهين") في أن الهدف من هذه السياسة هو تنظيم عمليات تطوير الأنظمة والتغييرات التقنية داخل بيئة الشركة بما يضمن إدماج ضوابط الأمن السيبراني في جميع مراحل التطوير، وحماية استقرار بيئة العمل الرقمية، ومنع التعديلات العشوائية، وضمان توثيق واعتماد جميع التغييرات الفنية والتشغيلية بطريقة محكومة ومستمرة تدعم استمرارية الأعمال والتعافي من الكوارث.

3. تعاريف:

- 3.1 منصة شاهين (Shahin Platform): المنصة الرقمية التابعة للشركة، والمتخصصة في ربط المنصة كوسيط تأميني بشركات التأمين لتسهيل عمليات الإصدار والتجديد وإدارة العملاء إلكترونياً.
- 3.2 تطوير البرمجيات الآمنة (SSDLC): الإطار المعتمد الذي يدمج ضوابط الأمن السيبراني في جميع مراحل التطوير بدءاً من التحليل وحتى الإطلاق.
- 3.3 اختبار القبول (UAT): مرحلة التحقق من مطابقة النظام لمتطلبات المستخدم النهائي قبل الإطلاق الفعلي.
- 3.4 نظام التحكم في النسخ (Version Control System): النظام الإلكتروني المعتمد لإدارة الإصدارات البرمجية وتوثيق التغييرات مثل Git.
- 3.5 خطة الرجوع (Rollback Plan): خطة الطوارئ التي تُمكن الفريق الفني من إعادة النظام إلى الإصدار السابق في حال فشل التحديث.
- 3.6 خطة استمرارية الأعمال (BCP) وخطة التعافي من الكوارث (DRP): الخطط المعتمدة التي تضمن استعادة الخدمات التشغيلية والتقنية في حال حدوث انقطاع أو خلل جسيم.

4. نطاق تطبيق السياسة:

4.1 تُطبّق هذه السياسة على

- 4.1.1 جميع الأنظمة التقنية المستخدمة أو المطوّرة داخل المنصة أو بواسطة أطراف خارجية نيابة عنها.
- 4.1.2 كافة الموظفين والمطورين ومسؤولي الأمن السيبراني الذين يشاركون في تطوير أو تعديل أو اختبار الأنظمة.
- 4.1.3 البنى التحتية الرقمية، قواعد البيانات، الأنظمة السحابية، والتكاملات التقنية (APIs) المرتبطة بالمنصة الرقمية.

5. القطاعات والإدارات ذات العلاقة:

- 5.1 إدارة تقنية المعلومات .
- 5.2 قسم الأمن السيبراني.
- 5.3 قسم تطوير البرمجيات.
- 5.4 إدارة الجودة والتطوير .

6. الكيانات ذات العلاقة:

- 6.1 هيئة التأمين.
- 6.2 هيئة الحكومة الرقمية (DGA).

7. قواعد عامة:

7.1 الالتزام العام

- 7.1.1 يجب أن تتبع جميع أنشطة تطوير الأنظمة دورة حياة برمجية موحدة (Application Lifecycle) معتمدة من إدارة تقنية المعلومات، تشمل مراحل: التحليل، التصميم، التطوير، الاختبار، الإطلاق، والمراجعة اللاحقة.
- 7.1.2 يُلزم فريق التطوير بتطبيق معايير Secure Software Development Lifecycle (SSDLC) لضمان إدماج ضوابط الأمن السيبراني في كل مرحلة من مراحل التطوير، بما في ذلك تحليل التهديدات وتقييم المخاطر الأمنية قبل كتابة أي كود.
- 7.1.3 يُحظر إجراء أي تطوير أو تعديل على الأنظمة دون موافقة مسبقة من مدير تقنية المعلومات ومسؤول الأمن السيبراني، على أن تُرفق الموافقة بتقرير تقييم أثر التغيير (Impact Assessment Report).
- 7.1.4 يجب أن تُنفذ جميع التحديثات ضمن بيئات عمل منفصلة (تطوير – اختبار – إنتاج) مع تطبيق مبدأ فصل المهام (Segregation of Duties)، بحيث لا يمتلك أي موظف صلاحية تنفيذ أكثر من مرحلة من مراحل التطوير أو النشر.
- 7.1.5 تلتزم جميع الفرق بتوثيق الإجراءات في نظام إدارة الوثائق التقنية المعتمد، مع مراجعتها نصف سنويًا لضمان التحديث والتوافق مع اللوائح.

7.2 إدارة التغييرات التقنية

- 7.2.1 يجب تسجيل جميع طلبات التغيير عبر نموذج رسمي معتمد في نظام التذاكر التقنية (Change Request Form) يتضمن: رقم الطلب، الجهة الطالبة، وصف التغيير، أثره على الأنظمة، تصنيفه (عاجل – دوري – طارئ)، ونتيجة التقييم الأمني.
- 7.2.2 تُنفذ التغييرات بعد اعتمادها من لجنة التغييرات التقنية (Change Control Committee) المكونة من ممثل تقنية المعلومات، ومسؤول الأمن السيبراني، ويجوز لإدارة الجودة والتطوير حضور اللجنة بصفة مراقب لضمان توثيق الإجراءات والامتثال للسياسات دون المشاركة في القرار الفني أو الأمني.
- 7.2.3 يُحظر تنفيذ أي تغيير في بيئة الإنتاج خارج أوقات العمل الرسمية أو دون إخطار مسبق لجميع المستخدمين المعنيين.
- 7.2.4 يجب اختبار جميع التغييرات في بيئة الاختبار قبل النقل إلى الإنتاج، ويُرفق تقرير نتائج الاختبار مع ملف التغيير النهائي.
- 7.2.5 يُمنع استخدام بيانات حقيقية أثناء الاختبار، ويجب استخدام بيانات تجريبية مجهولة (Sanitized Data) متوافقة مع سياسة حماية البيانات.
- 7.2.6 بعد اعتماد التغيير، تُزال جميع الحسابات المؤقتة وبيانات الاختبار قبل الإطلاق الفعلي.
- 7.2.7 تُراجع جميع التغييرات الحرجة بعد التنفيذ (Post-Change Review) خلال مدة لا تتجاوز 48 ساعة لتقييم الأثر وضمان استقرار الخدمة.

7.3 تطوير الأنظمة وضوابط الأمان:

- 7.3.1 يجب حماية الشيفرة البرمجية (Source Code) باستخدام أنظمة تحكم بالإصدارات (Version Control Systems) وتُمنح صلاحيات الوصول وفق مبدأ أقل امتياز (Least Privilege).
- 7.3.2 يُلزم تشفير جميع البيانات الحساسة أثناء النقل والتخزين باستخدام بروتوكولات التشفير المعتمدة (مثل TLS 1.2 أو أعلى، و AES-256).
- 7.3.3 تُنفذ مراجعات للكود البرمجي (Peer Code Review) من قبل مطور آخر معتمد قبل الدمج (Merge Approval).
- 7.3.4 تُمنع التعديلات المباشرة على النظام الإنتاجي دون اتباع مسار تغيير رسمي موثق في سجل التغييرات التقنية.
- 7.3.5 يجب إجراء اختبارات اختراق أمنية داخلية وخارجية بعد كل تطوير رئيسي أو تحديث للبنية التحتية، مع توثيق النتائج ومتابعة التصحيحات.
- 7.3.6 تُحفظ نتائج الاختبارات الأمنية ضمن تقارير رسمية معتمدة من إدارة تقنية المعلومات وتُراجع دوريًا من قبل الأمن السيبراني.
- 7.3.7 يجب تحديد المسؤولية الفردية عن أي تعديل في الكود البرمجي لضمان التتبع والمساءلة عند حدوث خطأ أو خلل تشغيلي.

7.4 القبول والتشغيل (User Acceptance Testing - UAT)

- 7.4.1 يجب على مالك النظام إعداد معايير قبول واضحة تشمل المتطلبات التشغيلية، الوظيفية، والأمنية، وتُراجع من قبل فريق تقنية المعلومات والأمن السيبراني قبل بدء الاختبارات.
- 7.4.2 لا يُسمح بترقية النظام إلى بيئة الإنتاج قبل استيفاء جميع معايير القبول المعتمدة من الأطراف ذات العلاقة (التقنية – الأمنية – التشغيلية).
- 7.4.3 يجب إجراء اختبارات الأداء (Performance Testing) والتكامل (Integration Testing) لضمان توافق النظام مع الأنظمة الأخرى المتصلة.

- 7.4.4 تُوثق نتائج الاختبارات في نموذج اختبار معتمد (UAT Report) يُرفق مع محضر القبول النهائي ويُحفظ في نظام إدارة الوثائق الرقمية.
- 7.4.5 يُلزم الفريق الفني بمعالجة جميع الملاحظات قبل الإطلاق النهائي، وتوثيق الموافقات الإلكترونية من جميع الأطراف المختصة.
- 7.5 معالجة الثغرات الأمنية والتصحيحات:
- 7.5.1 يجب تنفيذ فحص دوري للثغرات (Vulnerability Scan) على جميع الخوادم والأنظمة بعد كل تطوير جوهري أو تحديث للبنية التحتية.
- 7.5.2 تُطبق التحديثات الأمنية (Security Patches) وفق تصنيف الأولوية التالي:
- 7.5.2.1 حرجة (Critical): خلال 48 ساعة من الاكتشاف.
- 7.5.2.2 عالية (High): خلال 5 أيام عمل.
- 7.5.2.3 متوسطة (Medium): خلال أسبوعين.
- 7.5.2.4 منخفضة (Low): ضمن الصيانة الدورية الشهرية.
- 7.5.3 تُنفذ اختبارات إعادة التحقق (Re-Scan) بعد التصحيح لضمان إزالة الثغرات بالكامل.
- 7.5.4 يجب على الفريق الأمني إعداد تقرير دوري يوضح عدد الثغرات المكتشفة، المغلقة، والمتبقية، ويرفع إلى لجنة الأمن السيبراني ربع سنوياً.
- 7.5.5 تُراجع معايير إدارة الثغرات مرة سنوياً لتتوافق مع أفضل الممارسات الدولية مثل ISO/IEC 27001 و NIST SP 800-53.
- 7.6 استمرارية الأعمال والتعافي من الكوارث:
- 7.6.1 يجب دمج خطة استمرارية الأعمال (BCP) وخطة التعافي من الكوارث (DRP) ضمن دورة حياة التطوير لضمان جاهزية استعادة الخدمة في حال الانقطاع.
- 7.6.2 تُنفذ اختبارات محاكاة نصف سنوية للتحقق من قدرة النظام على استعادة الخدمة خلال الزمن المستهدف (RTO) المحدد من الإدارة التنفيذية.
- 7.6.3 تُحفظ النسخ الاحتياطية للأنظمة البرمجية والبيانات في موقعين جغرافيين مختلفين لضمان المرونة التشغيلية.
- 7.6.4 يجب اختبار صلاحية النسخ الاحتياطية (Backup Validation) دورياً وإثبات نجاح الاستعادة.
- 7.6.5 يُلزم الفريق الفني بتحديث خطة التعافي بعد كل تغيير رئيسي في النظام أو البنية التحتية التقنية.
- 7.6.6 في حال فشل أي اختبار استعادة، يجب تقديم تقرير تفصيلي يتضمن السبب، والإجراءات التصحيحية، والمواعيد المستهدفة للتنفيذ.
- 7.6.7 تُراجع إدارة تقنية المعلومات وثائق الإصدار قبل اعتمادها لضمان اكتمال المتطلبات الفنية والأمنية.
- 7.7 إدارة الإصدارات والتحكم في النسخ
- 7.7.1 يجب أن تُدار جميع إصدارات الأنظمة البرمجية عبر نظام تحكم بالنسخ (Version Control System) معتمد من إدارة تقنية المعلومات، مثل Git أو ما يعادله، ويُحظر أي تطوير خارج بيئة النسخ المركزية.
- 7.7.2 يُلزم الفريق الفني بتوثيق سجل الإصدارات (Release Notes) لكل تحديث، على أن يشمل: رقم الإصدار، وصف التغيير، التاريخ، الشخص المسؤول، وسجل المراجعة الأمنية قبل النشر.
- 7.7.3 يجب الاحتفاظ بنسخة تشغيلية مستقرة (Rollback Version) يمكن الرجوع إليها فوراً في حال فشل التحديث الجديد، وتُختبر جاهزيتها قبل كل عملية إطلاق رئيسية.
- 7.7.4 يمنع حذف أي إصدار سابق قبل مرور مدة لا تقل عن (6) أشهر من نشر الإصدار الجديد وبعد التحقق من استقرار النظام واستيفاء نتائج اختبار الاستقرار (Stability Test).
- 7.7.5 يجب اختبار التوافق بين الإصدارات (Backward Compatibility) لضمان عدم تأثر الأنظمة المترابطة مثل واجهات الربط الإلكتروني (API Integration) مع شركات التأمين، وتوثيق نتائج الاختبار ضمن ملف الإصدار.
- 7.8 المراجعة والاعتماد:
- 7.8.1 يجب أن تمر جميع التغييرات الجوهرية بثلاث مراحل اعتماد إلزامية لضمان سلامة التطوير وجودة التنفيذ:
- 7.8.1.1 الاعتماد الفني: من فريق التطوير بعد اجتياز اختبار الأداء والوظائف (Functionality & Performance Test).
- 7.8.1.2 الاعتماد الأمني: من مسؤول الأمن السيبراني بعد تنفيذ اختبار الثغرات وضمان سلامة الكود البرمجي.
- 7.8.1.3 الاعتماد التشغيلي: من مشرف/مدير تقنية المعلومات بعد التحقق من سلامة التنفيذ في بيئة الإنتاج، وتوثيق النتائج في نظام إدارة التغييرات.

- 7.8.2 لا يجوز إطلاق أي تحديث في بيئة الإنتاج دون استكمال الموافقات الثلاثة الموقعة إلكترونياً في نظام إدارة الوثائق التقنية، وتُعد أي مخالفة لذلك إخلالاً جسيماً بسياسة الأمن السيبراني.
- 7.8.3 يجب تسجيل جميع عمليات الاعتماد والإطلاق في سجل التغييرات (Change Log) متضمناً توقيت التنفيذ، الإصدار المعتمد، نطاق التغيير، الأثر المتوقع، والجهة المنفذة.
- 7.8.4 في حال ظهور أي خلل بعد الإطلاق، يُلزم الفريق الفني بتفعيل خطة الرجوع (Rollback Plan) فوراً، وإعداد تقرير أثر التغيير خلال (24) ساعة من اكتشاف الخلل، مع إخطار مدير تقنية المعلومات ومسؤول الأمن السيبراني.
- 7.8.5 يجب أن تُراجع لجنة التغييرات التقنية نتائج التنفيذ والملاحظات التشغيلية في أول اجتماع دوري لاحق لتحديد فرص التحسين أو الحاجة إلى تحديث السياسات ذات العلاقة.
- 7.9 المراجعة بعد التنفيذ (Post Implementation Review)
- 7.9.1 يجب إجراء تقييم شامل بعد كل تحديث رئيسي خلال (5) أيام عمل من تاريخ الإطلاق، للتحقق من استقرار النظام، الأداء، والأمان، وفق مؤشرات معتمدة مسبقاً من إدارة تقنية المعلومات.
- 7.9.2 يتضمن التقييم مراجعة مؤشرات الأداء الفعلية للنظام (مثل System Uptime, Response Time, Error Logs, Transaction Success Rate) وتحليل أي أعطال أو مشكلات أبلغ عنها المستخدمون أو فرق الدعم.
- 7.9.3 يلتزم فريق التطوير برفع تقرير ما بعد التنفيذ (Post Implementation Report) إلى إدارة تقنية المعلومات ومسؤول الأمن السيبراني، وترسل نسخة لإدارة الجودة والتطوير لغرض المراجعة الرقابية والتوثيق.
- 7.9.4 يجب توثيق الدروس المستفادة (Lessons Learned) من كل عملية تطوير أو تحديث، ومراجعتها في الاجتماع الفصلي للحوكمة التقنية لتضمينها في خطة التحسين المستمر (Continuous Improvement Plan).
- 7.9.5 تُراجع نتائج تقارير المراجعة بعد التنفيذ خلال اجتماعات لجنة الحوكمة التقنية (IT Governance Review)، ويُحدث سجل المخاطر التقنية بناءً على نتائج المراجعة عند الحاجة.
8. مسؤولية السياسة.
- 8.1 إدارة تقنية المعلومات:
- 8.1.1 مسؤولون عن الإشراف العام على تطبيق السياسة واعتماد جميع الإصدارات والتغييرات التقنية وضمان امتثالها للضوابط الأمنية.
- 8.2 قسم التطوير البرمجي:
- 8.2.1 مسؤولون عن تنفيذ مراحل التصميم، التطوير، الاختبار، وإعداد تقارير الأداء والقبول الفني.
- 8.3 مسؤول الأمن السيبراني:
- 8.3.1 مسؤول مهام فحص الثغرات، التحقق من سلامة الكود، واعتماد الجاهزية الأمنية قبل الإطلاق.
9. التعاميم والتعليمات ذات العلاقة:
- 9.1 هيئة الحكومة الرقمية (DGA) — «الإطار التنظيمي لأعمال الحكومة الرقمية»
- 9.2 الهيئة السعودية للبيانات والذكاء الاصطناعي (SDAIA) — حماية البيانات الشخصية.
- 9.3 البنك المركزي السعودي (SAMA) — الإطار التنظيمي لأمن المعلومات
10. حفظ السياسة:
- 10.1 تحفظ النسخة الإلكترونية الغير قابلة للنسخ من السياسة المعتمدة على نظام الموارد البشرية ويطلع عليها الإدارات ذات العلاقة.
- 10.2 تحفظ النسخة الورقية من السياسة المعتمدة في إدارة الجودة والتطوير حسب المدة النظامية المحددة في كتيب تقاؤم المستندات ترحل نظامياً إلى حفظ المستندات.
11. مخالفة السياسة:
- 11.1 يُطبق في حق المخالف لهذه السياسة ماورد في لائحة جزاءات شركة دايموند المعتمدة.





إدارة الجودة والتطوير
Quality & Development Management

Diamond Insurance Broker

**Systems Development
and Change Management Policy**

Nov 2025

Registered Name: Diamond Insurance Broker Company
Head Office: Al Thumama Road, Al Rabie District, Riyadh
Document Owner: Quality & Development Manager

Internal

DO NOT COPY

Translation

Contents	
1	Introduction.....
2	Policy Objective.....
3	Definitions.....
4	Scope of Application.....
5	Related Management and Sectors.....
6	Related Entity.....
7	General Rules.....
8	Policy Responsibility.....
9	Related Circulars and Instructions.....
10	Policy Retention.....
11	Policy Violation.....



إدارة الجودة والتطوير
Quality & Development Management

Article (1): This document and the information it contains are related to the Shahin digital platform. They may not be used, copied, or disclosed, in whole or in part, to any third party without the prior written consent of Diamond. This restricted notice may not be altered or removed from this document under any circumstances.

Article (2): In the event of any discrepancy between the Arabic and English texts, the Arabic text shall prevail.

1. Introduction

1.1 The Systems Development and Change Management Policy is a fundamental component in establishing a unified framework for governing systems development, ensuring compliance with cybersecurity standards, and preventing any unauthorized changes that may impact operational performance or data integrity.

2. Policy Objective

2.1 Diamond Insurance Brokers Company (hereinafter referred to as “Shahin”) believes that the objective of this policy is to regulate systems development and technical change activities within the Company’s environment in a manner that ensures the integration of cybersecurity controls throughout all development stages, protects the stability of the digital operating environment, prevents ad hoc modifications, and ensures that all technical and operational changes are properly documented and approved through a governed and continuous approach that supports business continuity and disaster recovery.

3. Definitions

3.1 **Shahin Platform:** The Company’s digital platform that operates as an insurance broker, connecting with insurance companies to facilitate electronic issuance, renewals, and customer management.

3.2 **Secure Software Development Lifecycle (SSDLC):** The approved framework that embeds cybersecurity controls across all development stages from analysis through release.

3.3 **User Acceptance Testing (UAT):** The validation phase to confirm that the system meets end-user requirements prior to go-live.

3.4 **Version Control System:** The approved system used to manage software versions and document changes (e.g., Git).

3.5 **Rollback Plan:** An emergency plan enabling the technical team to revert the system to the previous release in case an update fails.

3.6 **Business Continuity Plan (BCP) and Disaster Recovery Plan (DRP):** Approved plans that ensure restoration of operational and technical services in the event of significant disruption or outage.

4. Scope of Application

4.1 This policy applies to:

4.1.1 All technical systems used or developed within the platform, or developed by external parties on its behalf.

4.1.2 All employees, developers, and cybersecurity personnel involved in developing, modifying, or testing systems.

4.1.3 Digital infrastructure, databases, cloud systems, and technical integrations (APIs) associated with the digital platform.

5. Related Management and Sectors

5.1 Information Technology Department

5.2 Cybersecurity Department

5.3 Software Development Department

5.4 Quality and Development Department

6. Related Entity

6.1 Insurance Authority

6.2 Digital Government Authority (DGA)

7. General Rules

7.1 General Compliance

7.1.1 All systems development activities shall follow a unified application lifecycle approved by the Information Technology Department, including the following phases: analysis, design, development, testing, release, and post-release review.

7.1.2 The development team shall apply Secure Software Development Lifecycle (SSDLC) standards to ensure cybersecurity controls are embedded at every development phase, including threat analysis and security risk assessment prior to writing any code.

7.1.3 No development or modification shall be performed without prior approval from the IT Director and the Chief Information Security Officer (CISO), and such approval shall be supported by a Change Impact Assessment Report.

7.1.4 All updates shall be implemented within segregated environments (Development – Testing – Production) while applying Segregation of Duties, such that no individual holds authorization to execute more than one critical phase of development or deployment.

7.1.5 All teams shall document procedures in the approved technical document management system and review them semi-annually to ensure updates and regulatory alignment.

7.2 Technical Change Management

7.2.1 All change requests shall be logged using an officially approved Change Request Form in the ticketing system, including: request number, requesting party, change description, system impact, classification (Urgent – Routine – Emergency), and security assessment results.

7.2.2 Changes shall be implemented only after approval by the Change Control Committee, consisting of an IT representative and the CISO. The Quality and Development Department may attend as an observer to ensure documentation and policy compliance, without participating in technical or security decision-making.

7.2.3 Implementing any change in the production environment outside official working hours or without prior notification to all relevant users is prohibited.

7.2.4 All changes shall be tested in the testing environment prior to production deployment, and the test results report shall be attached to the final change file.

7.2.5 Using real data during testing is prohibited; only anonymized/sanitized test data compliant with the Data Protection Policy shall be used.

7.2.6 Following change approval, all temporary accounts and test data shall be removed prior to go-live.

7.2.7 All critical changes shall be subject to a Post-Change Review within a maximum of **48 hours** to assess impact and ensure service stability.

7.3 Systems Development and Security Controls

7.3.1 Source code shall be protected using Version Control Systems, and access privileges shall be granted based on the Least Privilege principle.

7.3.2 All sensitive data shall be encrypted in transit and at rest using approved encryption protocols (e.g., TLS 1.2 or higher, and AES-256).

7.3.3 Peer Code Reviews shall be performed by another authorized developer prior to merge approval.

7.3.4 Direct changes to the production environment are prohibited unless executed through an officially documented change path recorded in the technical change log.

7.3.5 Internal and external penetration tests shall be conducted after every major development or infrastructure update, and results shall be documented and remediation tracked.

7.3.6 Security testing results shall be retained within official IT-approved reports and periodically reviewed by the Cybersecurity function.

7.3.7 Individual accountability shall be established for every code modification to ensure traceability and enforce responsibility in the event of errors or operational failures.

7.4 User Acceptance Testing (UAT)

7.4.1 The System Owner shall define clear acceptance criteria covering operational, functional, and security requirements, and such criteria shall be reviewed by IT and Cybersecurity prior to testing.

7.4.2 No system shall be promoted to production unless all acceptance criteria are satisfied and approved by the relevant stakeholders (technical, security, and operational).

7.4.3 Performance Testing and Integration Testing shall be conducted to ensure compatibility with connected systems.

7.4.4 Testing outcomes shall be documented in an approved UAT Report, attached to the final acceptance minutes, and retained within the digital document management system.

7.4.5 The technical team shall resolve all observations prior to final release and obtain documented electronic approvals from all authorized parties.

7.5 Vulnerability Remediation and Patching

7.5.1 Periodic vulnerability scans shall be performed on all servers and systems following any major development or infrastructure update.

7.5.2 Security patches shall be applied according to the following priority classification:

7.5.2.1 **Critical:** within **48 hours** of discovery.

7.5.2.2 **High:** within **5 business days**.

7.5.2.3 **Medium:** within **two (2) weeks**.

7.5.2.4 **Low:** within routine monthly maintenance.

7.5.3 Re-scans shall be performed after remediation to confirm that vulnerabilities are fully eliminated.

7.5.4 The security team shall prepare periodic reports indicating the number of identified, closed, and outstanding vulnerabilities and submit them to the Cybersecurity Committee on a quarterly basis.

7.5.5 Vulnerability management criteria shall be reviewed annually to align with international best practices such as ISO/IEC 27001 and NIST SP 800-53.

7.6 Business Continuity and Disaster Recovery

7.6.1 Business Continuity (BCP) and Disaster Recovery (DRP) requirements shall be integrated into the development lifecycle to ensure readiness for service restoration in the event of disruption.

7.6.2 Semi-annual simulation tests shall be conducted to verify the system's ability to restore services within the target Recovery Time Objective (RTO) defined by executive management.

7.6.3 System and data backups shall be retained in two geographically separated locations to ensure operational resilience.

7.6.4 Backup validation shall be performed periodically, with evidence of successful restoration.

7.6.5 The technical team shall update the disaster recovery plan after every major system or infrastructure change.

7.6.6 If any recovery test fails, a detailed report shall be issued including root cause, corrective actions, and targeted implementation timelines.

7.6.7 The IT Department shall review release documentation prior to approval to ensure completeness of technical and security requirements.

7.7 Release Management and Version Control

7.7.1 All software releases shall be managed through an IT-approved Version Control System such as Git (or equivalent), and any development outside the centralized version control environment is prohibited.

7.7.2 The technical team shall maintain Release Notes for each update, including: release number, change description, date, responsible person, and security review record prior to deployment.

7.7.3 A stable rollback version shall be retained and immediately available in case the new update fails; its readiness shall be tested prior to each major release.

7.7.4 No prior release shall be deleted until at least **six (6) months** after the new release is deployed, and only after verifying system stability and completing stability testing.

7.7.5 Backward compatibility testing shall be conducted to ensure that interconnected systems (including API integrations with insurers) are not impacted, and results shall be documented in the release file.

7.8 Review and Approval

7.8.1 All material changes shall pass three mandatory approval stages to ensure development integrity and execution quality:

7.8.1.1 **Technical Approval:** by the development team after passing functionality and performance testing.

7.8.1.2 **Security Approval:** by the CISO after vulnerability testing and source code assurance.

7.8.1.3 **Operational Approval:** by the IT Supervisor/Manager after verifying safe implementation in production and documenting results in the change management system.

7.8.2 No production release shall be executed unless the three approvals are completed and electronically signed within the technical document management system. Any breach constitutes a major violation of the Cybersecurity Policy.

7.8.3 All approvals and deployments shall be recorded in the Change Log, including implementation time, approved release, change scope, expected impact, and executing party.

7.8.4 If any defect occurs post-release, the technical team shall immediately activate the Rollback Plan and issue a Change Impact Report within **24 hours** of identifying the defect, while notifying the IT Director and the CISO.

7.8.5 The Change Control Committee shall review execution outcomes and operational observations in its next scheduled meeting to identify improvement opportunities or determine the need to update related policies.

7.9 Post Implementation Review

7.9.1 A comprehensive evaluation shall be conducted after each major update within **five (5) business days** of release to verify system stability, performance, and security based on pre-approved IT metrics.

7.9.2 The evaluation shall include reviewing actual system performance indicators (e.g., System Uptime, Response Time, Error Logs, Transaction Success Rate) and analyzing any failures or issues reported by users or support teams.

7.9.3 The development team shall submit a Post Implementation Report to the IT Department and the CISO, and a copy shall be shared with the Quality and Development Department for governance review and documentation purposes.

7.9.4 Lessons learned from each development or update activity shall be documented and reviewed during the quarterly IT governance meeting to incorporate them into the Continuous Improvement Plan.

7.9.5 Post-implementation review outcomes shall be reviewed during IT Governance Review meetings, and the technical risk register shall be updated accordingly when required.

8. Policy Responsibility

8.1 Information Technology Department: Responsible for overall supervision of policy implementation, approving all releases and technical changes, and ensuring compliance with security controls.

8.2 Software Development Department: Responsible for executing design, development, and testing phases and preparing performance and technical acceptance reports.

8.3 Chief Information Security Officer (CISO): Responsible for vulnerability scanning, code integrity verification, and approving security readiness prior to release.

9. Related Circulars and Instructions

9.1 Digital Government Authority (DGA) — Digital Government Regulatory Framework.

9.2 Saudi Data & AI Authority (SDAIA) — Personal Data Protection requirements.

9.3 Saudi Central Bank (SAMA) — Information Security Regulatory Framework.

10. Policy Retention

10.1 The approved non-editable electronic version shall be retained in the HR system and made accessible to relevant departments.

10.2 The approved hard copy shall be retained by the Quality and Development Department in accordance with the document retention period defined in the Document Retention Schedule.

11. Policy Violation

11.1 Any violation of this policy shall be subject to the penalties stipulated in Diamond Insurance Brokers' approved Disciplinary and Sanctions Policy.